ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

AVEVA System Platform / Application Server (formerly Wonderware) · Component type: **Software Application (SAR) - SCADA/HMI** · Target SL = SL 3

Where to work	**ArchestrA IDE** (Galaxy) › **Configure › Security**: authentication mode + security groups/roles + object permissions; **Platform Manager** (deploy/undeploy); **Galaxy Repository (GR)** node; runtime InTouch/OMI viewers; **AVEVA Historian**. Underlying **Windows Server** hardening applies.
Interfaces / ports	SCADA/HMI application platform; ArchestrA messaging between platforms (network account); OPC UA / DA / SuiteLink to controllers; SQL Server (Galaxy + Historian); Web/OMI clients (HTTPS); RDP for engineering.
Notes	SAR (software application) - AVEVA System Platform / Application Server (formerly Wonderware). Platform controls are inherited from the Windows host cheat sheet - reference it alongside. Confirm version and whether OS-Group (AD) security is enabled.
How to read	Read-only: review the Galaxy security config, deployed platforms, and the hosting Windows policy. Native how-to + external-tool validation + pass. Scans authorized; exploit/fuzz only in an isolated environment.

Project capture & evidence handling - capture the full application backup + exports

Do this BEFORE working the checklist - screenshots of the config and programming screens are not enough on their own. Capture the application's own backup and exports so nothing is missed:
1. Take the native full backup / export first (read-only, before anything): the Galaxy backup (.cab) from the Galaxy Database Manager (SMC), the security model + role/user configuration, historian/config exports, and the platform logs.
2. Export the security config: users / roles / permissions, authentication / IdP settings, audit configuration, and TLS / certificate settings - as files and screenshots.
3. Collect the logs: application, service / wrapper, audit and event logs (exports), plus running-threads / diagnostics dumps where the product provides them.
4. Capture identity & version: product edition + version / patch level, installed modules / components, and the host OS / runtime (JRE / .NET) - screenshot the About / version screen.
5. Name + protect (keep everything): `<site>_<zone>_<assetTag>_<product>_<version>_<YYYYMMDD-HHMM>_<initials>` with the native backup extension + the exports; SHA-256 hash the backup; store **only** on the encrypted evidence share; the backup usually contains secrets / credentials - **never** email it in cleartext and follow the project retention / classification policy. Do not save admin passwords in tool profiles.
6. Then analyze offsite against the product-specific checklist, the product manuals, vendor research and experience; fill in the tool and auto-generate the report - and remember the manual fields the tool can't auto-write: the **executive-summary narrative**, the **overall assurance level + justification**, and the **punch-list**.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 1.1	Human user identification & auth	In ArchestrA IDE › Galaxy › **Configure Security**, set the authentication mode to **OS Group based** (or OS User) so every operator/engineer authenticates against Windows/AD before configuration or runtime access; do **not** leave security mode **None**. **Ext. tools:** ArchestrA IDE (Configure Security review).	Security mode enabled (OS Group/User); all access authenticated; not "None".	
SR/CR 1.2	Software process & device identification & authentication	Confirm devices and software processes are identified/authenticated to the component. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Software process & device identification & authentication verified individually.	
SR/CR 1.3	Account management	Manage **security groups** and **roles** mapped to AD/OS groups (operate vs configure vs administer) with least-privilege object permissions; no shared logins; disable unused roles. **Ext. tools:** ArchestrA IDE (security groups/roles); AD group review.	Accounts managed via OS groups; least-privilege; no shared logins.	
SR/CR 1.4	Identifier management	Confirm unique user identifiers (OS/AD) mapped to Galaxy roles and unique platform/node identities; no reuse. **Ext. tools:** AD / ArchestrA node review.	Unique user and node identifiers; no reuse.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 1.5	Authenticator management	With OS-based security, password policy is delegated to Windows/AD (length/complexity/expiry/history); change all defaults; manage lifecycle centrally. Galaxy-mode passwords, if used, must be strong. **Ext. tools:** AD password policy (secpol/GPO); Galaxy-security review.	Strong, centrally-managed authenticators; no defaults.	
SR 1.6	Wireless Access Management	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 1.7	Strength of password-based authentication	Confirm the password-strength policy (length/complexity/lifetime) meets SL-3. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.5** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of password-based authentication verified individually.	
SR/CR 1.8	PKI certificates	Confirm certificates for OMI/Web (IIS/HTTPS), OPC UA, and secured ArchestrA comms are CA-issued, valid, and not default self-signed; manage the trust store. **Ext. tools:** Browser/openssl (IIS 443, OPC UA 4840); cert store review.	CA-issued, valid certificates; defaults replaced.	
SR/CR 1.9	Strength of public key auth	Confirm TLS 1.2/1.3 with strong ciphers on Web/OMI/OPC UA; OPC UA policy Basic256Sha256+; no weak/expired certs. **Ext. tools:** testssl.sh; OPC UA client (policy check).	Strong certificate/TLS crypto; weak protocols disabled.	
SR/CR 1.10	Authenticator feedback	Confirm the ArchestrA/Platform Manager logon and OMI/Web logon mask password entry (no cleartext echo). **Ext. tools:** Visual verification.	Authenticators obscured during entry.	
SR/CR 1.11	Unsuccessful login attempts	Confirm lockout on repeated failed logins (AD account lockout for OS-based security) and that failures are recorded (audit trail / Windows security log). **Ext. tools:** AD lockout policy; audit / Event Viewer.	Failed logins locked out and logged.	
SR/CR 1.12	System use notification	Confirm the approved use-notification banner appears before access (Windows interactive-logon banner on the platform nodes; OMI/Web login notice where supported). **Ext. tools:** GPO logon banner; Web login review.	Approved use notification presented before access.	
SR 1.13	Access via untrusted networks	Confirm OMI/Web clients are reachable only from trusted zones or via a reverse proxy/VPN in a DMZ; ArchestrA messaging stays inside the control zone; deny direct access from untrusted networks. **Ext. tools:** Nmap (untrusted side); firewall/DMZ review.	Access from untrusted networks denied/brokered; remote via VPN/DMZ.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 2.1	Authorization enforcement	Confirm object/attribute **security classifications** (e.g. Operate, Secured Write, Verified Write, Tune, Configure) enforce what each role may command/change; unauthorized operations (override, config) denied; e-signature/verified-write where required. **Ext. tools:** ArchestrA IDE (object security classification review); attempt unauthorized action (isolated).	Least-privilege authorization enforced; secured/verified writes where required.	
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR 2.3	Use control for portable/mobile devices	Control removable media on the GR/platform nodes (Windows device control); no unmanaged media loads galaxies/updates. **Ext. tools:** GPO device-control review (see Windows sheet).	Removable-media use controlled on the nodes.	
SR/SAR 2.4	Mobile code	Restrict active/mobile code: OMI/Web content controlled, .NET/QuickScript logic in the Galaxy reviewed/limited, app allow-listing (AppLocker/WDAC) on the hosts; no untrusted code executes. **Ext. tools:** Galaxy script review; AppLocker/WDAC policy.	Only trusted Galaxy code runs; untrusted mobile code blocked.	SAR-specific.
SR/CR 2.5	Session lock	Confirm runtime auto-logoff on inactivity (OMI/InTouch session timeout) and OS screen-lock; re-authentication required to resume. **Ext. tools:** OMI/InTouch timeout config; GPO screen-lock.	Sessions lock/log off on inactivity; re-auth required.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 2.6	Remote session termination	Confirm OMI/Web/RDP sessions time out and can be terminated by admin; runtime clients logged off centrally. **Ext. tools:** Session timeout config; session review.	Remote sessions time out and are terminable on demand.	
SR/CR 2.7	Concurrent session control	Confirm concurrent client/Web sessions are limited by license/policy; no shared concurrent privileged logins. **Ext. tools:** Client/Web session review.	Concurrent sessions limited/monitored.	
SR/CR 2.8	Auditable events	Confirm the ArchestrA/Galaxy **audit trail** records operator actions, secured/verified writes, config changes, and logons with the user identity (e-signatures where required); forward to the SIEM; actions attributable. **Ext. tools:** Galaxy audit config; SIEM forwarding review.	Operator/config actions audited (e-signature) and attributable.	
SR/CR 2.9	Audit storage capacity	Confirm audit/alarm/history storage (SQL Server / AVEVA Historian) is sized, backed up, and offloaded so records are retained; forward security events to the SIEM. **Ext. tools:** SQL/Historian sizing; SIEM retention review.	Audit/history storage sized and retained.	
SR/CR 2.10	Response to audit processing failures	Confirm defined behavior on audit/history failure (alarm on store-forward stop, SIEM alert on forwarding loss); records not silently lost. **Ext. tools:** Historian alarms; SIEM agent-health alert.	Defined response to audit failure; alerting on loss.	
SR/CR 2.11	Timestamps	Confirm platforms, clients, and controllers are time-synced (NTP/AD) so audit/alarm/history timestamps are accurate and correlate. **Ext. tools:** w32tm / NTP config review.	Reliable, synchronized timestamps.	
SR/CR 2.12	Non-repudiation	Confirm actions are attributable to a specific user (non-repudiation). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Non-repudiation verified individually.	

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 3.1	Communication integrity	Use **secured ArchestrA communication** (encrypted platform-to-platform) and OPC UA sign+encrypt to controllers, plus TLS for OMI/Web; avoid legacy cleartext channels; segment SCADA traffic. **Ext. tools:** Wireshark (encrypted channels); OPC UA policy.	Comms integrity/confidentiality -protected on secured channels.	
SR/SAR 3.2	Protection from malicious code (component)	Confirm the hosts run endpoint protection compatible with the AVEVA compatibility matrix, app allow-listing, and Galaxy integrity controls so the SCADA application resists malicious code. **Ext. tools:** AV/allow-list review (per AVEVA compat); Galaxy integrity check.	Application protected from malicious code (allow-listed, AV per compat).	SAR-specific.
SR/CR 3.3	Security functionality verification	After change, re-verify the Galaxy security mode, groups/roles, object classifications, audit settings, certificates, and host hardening (STIG/CIS) against the baseline. **Ext. tools:** SCAP/STIG host scan; Galaxy security config compare.	Security settings match the baseline after change.	
SR/CR 3.4	Software & information integrity	Confirm Galaxy integrity: change control via the audit trail, controlled deployment (deploy/undeploy through Platform Manager), Galaxy backups (.cab), and verified writes so unauthorized changes are prevented/detected. **Ext. tools:** Galaxy backup/deploy review; audit-trail change history.	Galaxy integrity protected; unauthorized change prevented/detected.	
SR/CR 3.5	Input validation	Confirm exposed services (OMI/Web, OPC UA, SuiteLink) tolerate malformed input without crashing; keep patched to current AVEVA updates; fuzz only in a lab. **Ext. tools:** AVEVA security-bulletin/patch review; API fuzz (ISOLATED).	Patched against input-validation CVEs; no crash on malformed input.	Do NOT fuzz production.
SR/CR 3.6	Deterministic Output	**N/A.** Device does not drive process outputs; deterministic/fail-safe output is not applicable.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 3.7	Error handling	Confirm runtime handles faults/comm loss gracefully (platform redundancy failover where used, no info leakage in errors, clean recovery of deployed objects). **Ext. tools:** Redundancy/failover test (lab); error-handling review.	Graceful error handling; no sensitive info leak.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 3.8	Session integrity	Confirm OMI/Web/OPC UA/ArchestrA sessions are integrity-protected (TLS), replay-resistant; old sessions cannot be replayed. **Ext. tools:** Wireshark (TLS session inspection).	Sessions integrity-protected against replay/hijack.	
SR/CR 3.9	Protection of audit information	Protect the Galaxy audit trail and history: restricted DB access, forwarded to a write-once SIEM, so records cannot be altered/deleted by unauthorized users. **Ext. tools:** SQL permission review; SIEM immutability.	Audit records protected from unauthorized read/modify/delete.	

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 4.1	Information confidentiality	Confirm information confidentiality — sensitive data is protected in transit and at rest. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Information confidentiality verified individually.	
SR/CR 4.2	Information persistence	On decommission/reuse, remove the Galaxy, history, credentials, and certificates; sanitize the host storage (BitLocker crypto-erase / wipe) so data is not recoverable. **Ext. tools:** Galaxy/history removal; host sanitize (see Windows sheet).	Sensitive galaxy/history data purged on decommission.	
SR/CR 4.3	Use of cryptography	Confirm modern crypto for Web/OMI/OPC UA/secured ArchestrA comms (TLS 1.2/1.3, strong suites) and that stored credentials/keys are protected; disable weak protocols. **Ext. tools:** testssl.sh; crypto config review.	Modern crypto in use; weak protocols disabled.	

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 5.1	Network segmentation	Confirm the GR/application-server and controller networks are segmented (SCADA zone behind firewall), OMI/Web in a DMZ/reverse-proxy where remote, and only required flows cross the boundary. **Ext. tools:** Nmap by zone; firewall/DMZ review.	SCADA segmented into zones; only required flows cross.	
SR 5.2	Zone boundary protection	Confirm zone-boundary protection — only required flows cross the boundary (system SR / network device). **Steps:** for this product this is assessed with the same evidence as **SR/CR 5.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Zone boundary protection verified individually.	
SR 5.3	General-purpose person-to-person comms restrictions	Confirm the platform/GR nodes are single-purpose: email/IM/arbitrary web removed or blocked, app allow-listing + egress filtering so they cannot be used for person-to-person messaging. **Ext. tools:** App inventory; egress/proxy review.	No general-purpose person-to-person comms on the SCADA nodes.	
SR 5.4	Application partitioning	Confirm separation of engineering (IDE/GR) from operator (OMI/InTouch) roles and of platform functions; least-privilege accounts and, for high assurance, dedicated servers per function. **Ext. tools:** IDE/GR vs OMI separation review; role/account review.	Roles/applications partitioned to contain compromise.	

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 6.1	Audit log accessibility	Confirm Galaxy audit/alarms are readable/exportable and forwarded to the SIEM for continuous monitoring; the SCADA zone is monitored (OT IDS). **Ext. tools:** Syslog/SIEM forwarding; passive OT IDS.	Events accessible/exportable and monitored in near-real-time.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 7.1	Denial-of-service protection	Confirm DoS resilience: host firewall + platform redundancy, only required services exposed, connection limits; a flood does not deny SCADA operation. **Ext. tools:** Get-NetFirewallProfile; Nmap; load test (ISOLATED).	Attack surface minimized; SCADA resists DoS (redundancy where used).	
SR/CR 7.2	Resource management	Confirm host/DB resource controls (CPU/memory/disk limits, SQL/Historian sizing, history rotation) so one process cannot starve the SCADA server. **Ext. tools:** Performance Monitor; SQL/Historian config review.	Resources bounded; no single-process exhaustion.	
SR/CR 7.3	Control system backup	Confirm the Galaxy (.cab), history, and server images are backed up (versioned, offline) and restore is tested for a known-good rebuild; redundancy validated. **Ext. tools:** Backup repository review; Galaxy restore test (lab).	Backups current and recovery validated.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Network & security configuration settings	Confirm hardening: unused platform options/Web disabled, host services minimized (per the AVEVA security guideline), SQL/OPC endpoints restricted. **Ext. tools:** Service/option review; Nmap (exposed services).	Least functionality; unused services disabled per baseline.	
SR/CR 7.7	Least functionality	Confirm least functionality — unused services/ports/protocols are disabled. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Least functionality verified individually.	
SR/CR 7.8	Component inventory	Confirm the System Platform version, patches, options, and host are inventoried so vulnerabilities track against AVEVA security bulletins. **Ext. tools:** ReadOnlyEnum; version/patch inventory.	Accurate software/version inventory maintained.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
ArchestrA IDE (Galaxy security)	Identity, roles & authorization review (FR1, 2.1, 2.8)	Read the authentication mode, security groups/roles, object security classifications, and audit trail; confirm least privilege.	Read/authorized copy.
SCAP/STIG (host)	Host hardening verification (3.3, 7.6)	Scan the hosting Windows Server against STIG/CIS; reference the Windows cheat sheet.	Authorized.
Nmap / ReadOnlyEnum	Exposed-service & zone enumeration (1.13, 5.x, 7.6, 7.8)	Enumerate OMI/Web/OPC UA/SQL/RDP from each zone; confirm only required services reachable.	Read-only; authorized.

Tool / method	Verifies	How to use — steps / example	Constraints
testssl.sh / OPC UA client	TLS & OPC UA strength (1.8, 1.9, 4.3)	Check TLS/cipher strength on IIS/OMI and the OPC UA security policy.	Non-intrusive.
Wireshark	Comms integrity review (3.1, 3.8)	Confirm secured ArchestrA/OPC UA channels are encrypted+authenticated; cleartext contained to the zone.	Passive capture.
Syslog listener + SIEM	Event forwarding & monitoring (2.8-2.10, 6.x)	Confirm audit/security events reach the SIEM; trigger a test event.	Coordinate with SIEM team.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.